

Deval Kotak

Mumbai, India | devalktk@gmail.com | github.com/devalkotak | linkedin.com/in/devalkotak | devalkotak.github.io

I build security systems for the people who inherit them, meant to outlast me. I'd rather remove a misconfiguration than get alerted about one: alerts are unfinished work, and a real fix disappears into the system instead of needing someone to watch it.

SKILLS

Languages: Python, Bash, SQL, JavaScript (Node.js)

Security Tools: Burp Suite, OWASP ZAP, Nuclei, Wireshark, Nmap, Postman, Coralogix

Cybersecurity: Penetration Testing, VAPT, OWASP Top 10, Web Application Security, API Security Testing, SAST, DAST, SIEM, DLP, Vulnerability Assessment, Threat Modeling (STRIDE), Incident Triage

CTF & Security Labs: TryHackMe, HackTheBox, PortSwigger, PicoCTF, OverTheWire, DVWA, OWASP Juice Shop; competed in CSAW-CTF, CrewCTF, PragyanCTF, AnveshamCTF, Breachbytes-CTF

Cloud Security: AWS, Terraform, IAM, S3, EC2, VPC, Security Groups, CloudTrail, GuardDuty, Least Privilege

GRC: Risk Assessment, Audit Management, ISO 27001, DPDP Act, Compliance Mapping, Regulatory Compliance, Vulnerability Management, CIS Benchmarks

Data Engineering: SQL, dbt, DuckDB, Airflow, Data Modeling (Star Schema), ETL/ELT Pipelines, Data Quality Testing, Pandas, NumPy, Advanced Excel

EXPERIENCE

JioStar (Mumbai, India)

Cybersecurity Intern

Feb 2026 – Aug 2026

- Shipped an automated regression testing engine integrated with Jira and GitHub that cut security test-case creation from 2 hours to 20 seconds, turning regression testing into a standing capability instead of a manual one-off.
- Designed a triage layer over the existing SIEM that automatically classifies DLP & InfraSec Alerts and filters false positives, cutting the noise analysts review before a real alert surfaces.
- Automated the User Access Review process for 6,000+ users across 650+ apps every quarter, managing reminders, approvals, evidence collection, and fulfillment tracking end to end to solidify access governance.
- Delivered an API inventory scanner that discovers and maps exposed endpoints across production, giving the team visibility into attack surface.
- Developed a persistent Telegram crawler fleet that passively monitors channels for piracy intelligence, surfacing leaks without manual searching.
- Conducted API security testing and VAPT for internal tools, identifying exploitable flaws and documenting remediation steps for the owning teams.
- Created Slackbots and Chrome extensions that automate recurring security workflows, removing repetitive manual steps from daily operations.
- Contributed to a multi-agent VAPT system that runs automated SAST and validation, catching issue classes that manual review misses and widening coverage across the codebase.

PROJECTS

Reachability CVE Triage *Python*

- Built a dependency-vulnerability triage tool that ranks findings by whether application code can actually reach the vulnerable path, using an AST import graph and route detection to filter out unreachable CVEs that would otherwise waste triage time.
- Pulls live data from OSV and CISA KEV and emits SARIF and JSON so results drop straight into CI code-scanning; packaged as a reusable GitHub Action.
- Modeled the tool's own attack surface with STRIDE, documenting trust boundaries across untrusted repository input, third-party advisory feeds, and SARIF output, and fixed three confirmed findings including an unhandled parser crash and an unvalidated feed URL.

LLM Security Lab: OWASP LLM Top 10 *Python, In Progress*

- Building a lab against a vulnerable LLM ReAct agent to reproduce direct and indirect prompt injection, system-prompt leakage, insecure output handling, and excessive agency, mapped to the OWASP LLM Top 10 (2025).
- Implementing and testing a defense for each attack using open-source guardrail libraries, then re-running the same attack against the defended version to confirm it is blocked.

CIS Compliance Checker *Python*

- Wrote a policy-as-code tool that checks a machine's configuration against CIS Benchmark controls and reports pass or fail against each control ID, turning a manual audit checklist into an automated scan.
- Structured it as pluggable modules, starting with the Windows baseline and leaving clean extension points for macOS, Linux, and AWS.

AWS Control Mapping & Risk Register *AWS, GRC*

- Deployed a small AWS environment (EC2, S3, IAM, VPC) and built a risk register mapping each asset to realistic threats, likelihood, and impact based on the actual configuration.
- Mapped the environment against CIS AWS Foundations Benchmark and ISO 27001 controls, documenting evidence and pass/fail status for each control.

Secrets in Git History Scanner *Python*

- Created a tool that scans a repository's full commit history for leaked secrets, flagging credentials still recoverable from deleted commits that current-state scanners miss.
- Combined pattern matching and entropy analysis for detection, and validated results against a seeded test repository with known planted secrets.

IaC Misconfiguration Scanner *Python, Terraform*

- Developed a scanner that parses Terraform configuration files and flags misconfigurations against CIS AWS Foundations Benchmark controls before deployment.
- Tested the scanner against real infrastructure from the AWS risk-register project, confirming it caught the same misconfigurations identified manually.

Data Pipeline: DuckDB and dbt *Data Engineering*

- Rebuilt an existing SQL data-warehouse project into a proper pipeline: modeled a star schema, added an ingestion layer, and migrated transformations into dbt across staging and mart layers.
- Added data-quality tests at each stage and kept the project fully reproducible on DuckDB with no external server or cloud dependency.

EDUCATION

Dwarkadas J. Sanghvi College of Engineering (Mumbai, India)

B.Tech, Computer Science and Engineering (IoT, Cybersecurity and Blockchain Technology)

June 2026

LEADERSHIP EXPERIENCE

DJS ISACA (Mumbai, India)

Vice President

Jul 2024 – Aug 2025

- Designed web exploitation and cryptography challenges simulating OWASP Top 10 vulnerabilities for the Breachbytes 2.0 CTF (80+ participants) and ran the technical infrastructure and secure API integrations for SYN3ERGY 2.0, a 24-hour intercollege hackathon.
- Taught hands-on ethical hacking and network security sessions to 80+ students on Burp Suite and Wireshark, covering practical exploitation and traffic analysis.
- Planned the committee's technical events end to end and conducted 80+ interviews to build the next core team.

Optiverse – Student Led Organization (Global, Remote)

Co-Founder

Mar 2021 – Present

- Directed strategy and operations for a 250+ member organization across 19 countries, building the programs and structure that keep it running.
- Ran 90+ educational workshops (50–250 participants) and two 2-month internship programs at an 8% acceptance rate, aimed at students aged 11–17.
- Partnered with NGOs including Lakshya and Lotus Petal Foundation, earning recognition from Lady Gaga's Born This Way Foundation.

DJS Trinity (Mumbai, India)

Co-Chairperson

Aug 2024 – Apr 2025

- Led a 150+ person team across the tenure, running a 3-day college festival spanning inter- and intra-college technical, non-technical, and sports competitions, and owning budget, logistics, venue production, and security for 1000+ attendees per night.
- Managed artist bookings, sponsorships, and fundraising throughout the tenure, and coordinated crowd control and police permissions to keep the festival running smoothly at scale.
- Oversaw social media coverage, creation, management and launched new event formats including a national-level drone race, coordinating external vendors and publicity.